

TLP:CLEAR

INCIDENT REPORT

A Multi-Brand Phishing Operation Exposed by a Public Cloud Bucket

Phishing • Credential Harvesting • Public Bucket Exposure • BEC • Open Redirect

Parameter	Value
Incident date	2026-08-06 – 2026-08-10 (active); Operator A ongoing since 2026-07-21
Report date	2026-08-10
Classification	Credential phishing / commodity phishing operations
Threat level	HIGH
Operators	Three concurrent (A: webmail re-validation; B: multi-brand kit farm; C: DocuSign BEC)
Source	Inbound email monitoring (aggregated sensor telemetry) + open-bucket analysis

1. Executive Summary

While monitoring inbound mail for a civil-society organization, we observed three concurrent phishing operations in early August 2026. One of them exposed its entire tooling through a world-listable Google Cloud Storage bucket (`storage.googleapis[.]com/cloakier/`), letting us map a single actor running six brand-impersonation kits — Webmail/Roundcube, DocuSign, LinkedIn, Microsoft Teams/Zoom, Office 365 Excel, and a procurement lure — from one staging area, with credential exfiltration split across several back-ends including a Telegram bot.

This report focuses on that operator (Operator B) and briefly documents the two operators seen alongside it, because together they illustrate the current commodity-phishing playbook against small organizations: spoof an internal or trusted brand, hide the real payload behind a trusted platform (object storage, URL shorteners, open redirects on aged legitimate domains), and collect credentials on rotating back-ends.

Key findings

- A public, unauthenticated GCS bucket staged 29 objects comprising six distinct phishing kits and their decoy assets.
- Credential exfiltration used at least four attacker endpoints (two branches of one attacker domain plus two sibling hosts) and a Telegram bot for real-time delivery.
- The kits use platform-trust evasion: object storage for hosting, a blob: URL loader to hide the malicious origin from the address bar, and IPFS-hosted decoy error pages for analyst GET requests.
- Two concurrent operators hit the same organization: one running a persistent 3-week "webmail re-validation" campaign harvesting credentials to a shared form-service form ID, and one running a DocuSign-branded BEC spray that abuses an open redirect on an aged legitimate domain to reach a compromised WordPress redirector.
- Recurring discipline point for defenders: the compromised legitimate sites and residential relays in these chains are victims — block the URL path, not the domain or the IP.

2. Operator B — the multi-brand kit farm

2.1. The exposure

The operator staged kits in a Google Cloud Storage bucket that was left world-listable. An anonymous request to the bucket root returned a complete object listing — no credentials required — revealing the actor's full inventory:

Folder	Brand impersonated	Credential exfil back-end
nd/	Webmail / DocuSign	<code>ww2.crhamericasmaterial[.]com/nd/2.php</code>
LinkedIn kit	LinkedIn (zh-Hant locale)	<code>ww2.crhamericasmaterial[.]com/vicar/submit.php</code>
"Sign-in" kit	generic SSO	<code>ww2.crhamericasmaterial[.]com/vicar/1.php</code>
Teams kit	Microsoft Teams / Zoom	<code>clapstickmkt.name[.]ng/rst/1.php</code> + Telegram bot
expoerr/	Office 365 Excel	<code>stockltd.duckdns[.]org/expo/ali.php</code> (offline)
new/	Made-in-China / procurement	not recovered (obfuscated; loader absent)

The DocuSign/Webmail kit (`nd/sonic.html`) was the one delivered to our monitored organization on 2026-08-08 as an "Action Required: Document Review" lure. It is one campaign of six.

2.2. Evasion techniques

- Platform trust for hosting. The kits live in Google Cloud Storage; landing links pass through Google's google.com/url?q= wrapper because the delivery mail traversed Gmail. Reputation systems see only trusted domains.
- blob: URL loader. The newest kit (updated 2026-08-06) uses a small loader that reads the victim's email from the URL fragment, fetches the page body, rebuilds it in memory, and redirects to a blob: URL — so the browser address bar never shows the malicious host.
- Analyst decoys. GET requests to the live .php exfil endpoints bounce (302) to an index.php or to an IPFS-hosted error page; credential capture only fires on a POST from the kit. Liveness of an endpoint is therefore not proof of a captured-credential flow.
- Telegram exfil. The Teams kit posts captured credentials to a Telegram bot in addition to a PHP endpoint, giving the operator real-time delivery. (Bot identifiers withheld from this public version.)

2.3. Back-end footprint

- crhamericasmaterial[.]com — registered 2026-05-08, fronted by Cloudflare, two exfil branches (/nd/, /vicar/).
- clapstickmkt.name[.]ng — Teams-kit exfil, behind Cloudflare.
- stockltd.duckdns[.]org — Office 365-kit exfil, offline at time of writing.
- Sending domain acemmetric[.]com (A = 45[.]74[.]252[.]189, Valkyrie Hosting) delivered the DocuSign-themed message with a spoofed internal From.

3. Operator A — persistent "webmail re-validation" credphish

Running in parallel (and continuously for ~3 weeks, from 2026-07-21 into August), a separate operator spoofed the organization's own Admin@ address with account-verification and password-reminder lures. The Roundcube-clone kit is hosted on a rotation of compromised legitimate WordPress sites and trusted object storage, and it dynamically brands itself to the victim — pulling the target's logo and a screenshot of the target's own website into the page background, with the victim's email read from the URL fragment.

All variants exfiltrate to a single form-service form ID (a Formspark endpoint). This form ID is the stable pivot — the same identifier links this campaign to an earlier wave we documented (Compromised-WordPress credential phishing, 2026-07-07). The sending infrastructure is a bulletproof /24 (Pitline Ltd, NL).

This continuity is the practical lesson: sending IPs and compromised host front-ends rotate freely, but the collection form ID persists — track the exfil identity, not the delivery infrastructure.

4. Operator C — DocuSign-spoof BEC via an open redirect

A third, short-lived operation (2026-08-06 to 08-09) sprayed a DocuSign-branded "signature required / payment instruction" lure across the organization's finance and administrative mailboxes. The sender was spoofed as dse_na2@docusign[.]net (SPF Fail) and injected directly from rotating residential relays.

The weaponized link did not point at the payload directly. It used an open redirect on an aged, legitimate membership website (a Liferay find_entry endpoint with a noSuchEntryRedirect= parameter — a legitimate feature abused as a redirector) to bounce the victim to a compromised WordPress site hosting the next stage. Because the first hop is a 1998-era domain behind Cloudflare, reputation filters pass it. The final kit was already removed or cloaking by the time of analysis, so credential/payment capture is inferred from the template, not directly observed.

5. Defender guidance

- Weight authentication results, not surface signals. All three operations relied on spoofing (SPF fail/softfail, absent DKIM, misaligned DMARC). A scorer that trusts DMARC alignment over "looks like a brand" or an abuse-listed shared IP would have correctly ranked these.
- Block URL paths, not victim domains. Compromised legitimate sites and residential relays appear throughout. Blocking the domain or IP harms the victim; block the specific path.
- Treat trusted-platform links as first-class phishing hosts. Object storage (GCS, Backblaze), URL shorteners, and open redirects on aged domains are the current default for hiding payloads behind good reputation.
- Pivot on the exfil identity. Form-service form IDs, Telegram bot identifiers, and attacker back-end paths persist across delivery-infrastructure rotation far better than sending IPs.
- Check your own cloud buckets. Operator B's entire toolkit was exposed by a single world-listable bucket. The same misconfiguration that helps defenders here is one your organization can make.

6. Indicators of Compromise (defanged)

6.1. Operator B — multi-brand kit farm

Type	Value
URL (staging)	hxxps://storage.googleapis[.]com/cloakier/
URL (exfil)	hxxps://ww2.crhamericasmaterial[.]com/nd/2.php
URL (exfil)	hxxps://ww2.crhamericasmaterial[.]com/vicar/submit.php
URL (exfil)	hxxps://ww2.crhamericasmaterial[.]com/vicar/1.php
URL (exfil)	hxxps://clapstickmkt.name[.]ng/rst/1.php
URL (exfil)	hxxps://stockltd.duckdns[.]org/expo/ali.php (offline)
Domain	crhamericasmaterial[.]com
Domain	acemmetric[.]com
IP (sender)	45[.]74[.]252[.]189

6.2. Operator A — webmail re-validation credphish

Type	Value
URL (exfil)	hxxps://submit-form[.]com/4FJePSjAq (form ID — pivot; shared service, do not block domain)
URL (kit path)	hxxps://habitatcyprus[.]com/wp-includes/build/ (compromised site — block path only)
Host (kit)	emailportalverify-gg218lv3x.edgeone[.]app
IP (sender)	77[.]83[.]39[.]10, .14, .15, .17, .24 (Pitline Ltd /24, NL)
IP (sender)	198[.]135[.]51[.]150

6.3. Operator C — DocuSign-spoof BEC

Type	Value
URL (open-redirect)	hxxps://members.universityclubofstpaul[.]com/c/blogs/

hop)	find_entry?...noSuchEntryRedirect=... (aged legit domain — block path only)
URL (compromised WP)	hxxps://kingcrossingbookclub[.]org/Goodsdys/redirect.php (compromised site — block path only)
Spoofed sender	dse_na2@docusign[.]net (real brand address — do not block)
IP (residential relay)	103[.]174[.]214[.]188, 186[.]19[.]160[.]163 (compromised hosts — do not block)

7. MITRE ATT&CK

T1566.002 (Spearphishing Link), T1656 (Impersonation), T1585.002 (Establish Accounts: Email), T1584.006 (Compromise Infrastructure), T1608.005 (Stage Capabilities: Link Target), T1102 (Web Service).

TLP:CLEAR — This document may be distributed without restriction.